INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Genel Sürüm · Şişeleme Hattı

Tüm laboratuvarlar gün boyu gelişen tek bir örnek makine — jenerik şişeleme hattı — üzerinde işlenir.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat C Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

LABORATUVAR 1 · GENEL SÜRÜM · Şişeleme Hattı

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.



Görev — sırayla cevaplayın

1. Bu makinede tehlike nedir? İnsan neyden zarar görür?

   Aşağı inen pnömatik dolum nozulları ile yüksek devirli döner kapak kapatma kafası; el/parmak sıkışması, ezilmesi ve kırılması.

2. Safety function (emniyet fonksiyonu) hangisidir?
   Işık perdesi ihlali veya E-stop basıldığında Safety PLC üzerinden STO tetiklenerek nozul pistonlarının ve kapaklama motorunun anında enerjisiz bırakılıp durdurulması.

3. Safety-related control system nerede? Şemada işaretleyin.

   Alttaki kırmızı renkle gösterilen hattın tamamı.

4. Normal PLC ile Safety PLC farkı nedir?

   Normal PLC sadece üretim kodunu yürütür ve donanım arızasını fark etmeyebilir; Safety PLC ise yedekli (çift işlemcili) mimarisiyle her türlü hata veya arızada sistemi zorunlu olarak güvenli duruma (Fail-Safe) geçirir.

5. PLr / SIL neden var? Bu fonksiyon için neden önemli?

   Makinelerdeki riskin ağırlığına göre emniyet sisteminin güvenilirlik seviyesini belirler; uzuv ezilmesi ve kopması riski yüksek olduğundan fonksiyonun yüksek bir güvenlik seviyesine (PL d/e, SIL 2/3) sahip olması şarttır.

6. Safe state (güvenli durum) nedir?

   Motorların torkunun kesildiği (STO), pnömatik nozulların kilitlendiği/basıncının boşaltıldığı ve insana zarar verecek tüm mekanik hareketlerin tamamen durduğu andır.

7. Safety function hangi dijital bağımlılıklara sahip?

   Safety PLC içindeki güvenlik yazılımı/konfigürasyonuna ve sarı kesikli çizgiyle bağlı IPC / Uzak Erişim modülünden gelebilecek dijital parametre değişikliklerine.

8. Siber müdahale hangi noktadan bu fonksiyonu bozar?

   Şemada sarı kesikli çizgiyle gösterilen "dijital kesişim noktası" üzerinden bozar.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI · Robot kontrolörü · **Safety PLC** · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı (ERP/e-posta)

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Kurumsal Bölge (Enterprise Zone): Ofis ağı (ERP/e-posta).
Operasyon / İzleme Bölgesi (Supervisory Zone): SCADA istemcisi, Mühendislik istasyonu.
Hücre / Kontrol Bölgesi (Cell / Control Zone): Trepak Üretim PLC'si, HMI, Robot kontrolörü (şişe besleme/indeksleme).
Emniyet Bölgesi (Safety Zone): Safety PLC.
Uzak Erişim Bölgesi (DMZ): Uzak servis erişimi.

2 Safety PLC'yi hangi bölgeye koydunuz — neden?

Bölge: Bağımsız Safety Zone (Emniyet Bölgesi).
Nedeni: Trepak dolum nozulları ve döner kapak kafasındaki insan can güvenliğini (E-stop, ışık perdesi, kapak kilitleri) yönetir. Üretim PLC'sindeki trafik yoğunluğundan, ağ saldırılarından ve yazılım çökmelerinden tamamen yalıtılmış olmak zorundadır.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Conduit 1 (Ofis SCADA): Firewall üzerinde; yalnızca tanımlı veri tabanı portları ve yetkili IP trafiği kontrol edilir.
Conduit 2 (SCADA Trepak PLC/HMI): Hücre switch/firewall'unda; yalnızca endüstriyel protokoller (Profinet/Modbus) ve reçete veri paketleri denetlenir.
Conduit 3 (Uzak Servis Jump Server PLC): DMZ ağ geçidinde; VPN tüneli, MFA kimlik doğrulaması ve bakım oturumu kısıtları kontrol edilir.
Conduit 4 (Kontrol Ağı Safety PLC): Emniyet ağ geçidinde; yalnızca tek yönlü durum okuma (Read-Only); dışarıdan Safety parametresi yazılması kesinlikle engellenir.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server:** Trepak servis mühendisi doğrudan PLC'ye ulaşmamalı; DMZ'deki izole ara sunucu üzerinden kontrollü bağlanmalıdır.
Tünel?	Açık / VPN	**VPN:** İnternet üzerindeki bakım trafiğinin dinlenmesini ve araya girilmesini önlemek için IPsec/SSL ile uçtan uca şifrelenmelidir.
Kimlik?	Parola / MFA	**MFA:** Statik şifrelerin sızması veya çalınması riskine karşı SMS/Authenticator tabanlı iki aşamalı doğrulama zorunlu olmalıdır.
Hesap?	Paylaşılan / Kişisel	**Kişisel:** Ortak şifreler kapatılmalı; dolum/kapaklama parametrelerini kimin değiştirdiğini izlemek (hesap verebilirlik) için her uzmana ayrı hesap verilmelidir.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı:** Makineye gönderilen tüm komutlar ve ekran hareketleri olası bir arıza/sabotaj incelemesinde adli delil için kaydedilmelidir.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı:** Saldırı yüzeyini en aza indirmek için hat sürekli açık kalmamalı; yalnızca bakım gerektiğinde operatörün onayıyla geçici açılmalıdır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · GENEL SÜRÜM · Şişeleme Hattı

Threat C Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç.** Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Senaryo 1 (Fırsatçı Dış): Otomatik bot **Uzak servis modülü portu** > PLC dolum nozulu zamanlamasını bozar > Operatör sıkışan şişeyi düzeltirken nozul aniden iner, **el ezilmesi ve delici yaralanma** oluşur.	3	3	3	27	**Kritik**
Senaryo 2 (Meraklı İçeriden): Hat çalışanı > Paylaşılan şifreyle **HMI paneli** > Döner kapaklama kafasının tork/hız limitini artırır > Operatör kapak sıkışmasını açarken kafa aniden döner, **parmak kopması/kırılması** gerçekleşir.	2	3	1	6	**Orta (Öne Alınır: S=3)**
Senaryo 3 (Tedarik Zinciri / Servis): Bakım teknisyeni > Dizüstü bilgisayar/USB ile **Mühendislik portu** > PLC'ye hatalı firmware yükleyip optik ışık perdesini bypass eder > Operatör hatta müdahale ederken konveyör ve nozullar durmaz, **uzuv sıkışması** yaşanır.	1	3	1	3	**Düşük (Öne Alınır: S=3)**

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

Senaryo 1 (Fırsatçı Dış) en yüksek önceliklidir; çünkü internete doğrudan açık uzak servis kapısından kolayca tetiklenebilmekte ($L=3, E=3$) ve doğrudan uzuv ezilmesine ($S=3$) yol açarak maksimum risk puanı olan 27'ye (Kritik) ulaşmaktadır.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet; Senaryo 2 (Skor: 6) ve Senaryo 3 (Skor: 3) yerel/fiziksel erişim gerektirdiği için (E=1) matematiksel skorları düşük kalmıştır.
Nasıl görünür kılınır?: Kural gereği S=3 (insana ağır fiziksel zarar/uzuv kaybı) içeren senaryolar skora bakılmaksızın doğrudan en öncelikli risk listesine çekilir, kırmızı uyarı bayrağı ile işaretlenir ve acil kapatılacak açıklar arasına alınır.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

```
İnternet / Dış Servis > Doğrudan Trepak Uzak Erişim Modülü > Trepak Kontrol & Emniyet PLC'si
```

HEDEF (beş ilkeyle yeniden tasarlayın)

```
Bakım Mühendisi > VPN > MFA & Kişisel Hesap > DMZ içi Jump Server > Trepak Üretim Ağı
```

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?
Hayır, etkilenmez. Emniyet fonksiyonu bağımsız bir Safety PLC üzerinde ayrı bir emniyet yolunda çalışır; saldırgan kontrol PLC'sini veya uzak erişim modülünü ele geçirse bile ışık perdesi ve E-stop zinciri donanımsal olarak torku keserek (STO) dolum nozullarını ve kapaklama motorunu durdurur.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

"Trepak makinesinin proses kontrol sisteminde, haberleşme ağında veya harici uzak bağlantı katmanında yaşanabilecek herhangi bir siber sızma, arıza ya da yazılımsal kesinti; emniyet fonksiyonunun tehlike anında sistemi gecikmesiz biçimde güvenli duruma (Safe State) geçirme yeteneğini hiçbir koşulda geçersiz kılamaz (bypass edemez) veya engelleyemez olmalıdır."

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: **SBOM** = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)
Bileşen var mı: Evet, Trepak PLC'sinde Component X kütüphanesi kullanılmaktadır.
Sürüm etkileniyor mu: Evet, makinedeki firmware sürümü 2.4'tür.
Açık ulaşılabilir mi: Evet/Kısmen; PLC harici ağa/uzak erişim modülüne bağlıysa açıktır.
Sonuç: Üç şart da sağlandığı için bu CVE sistemi doğrudan etkiler.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?
Hayır, hemen durdurulmaz. Endüstriyel otomasyonda planlanmamış anlık duruşlar (dolu şişelerin bantta kalması, nozul tıkanması, yüksek maliyet) operasyonu bozar; acil durdurma yerine önce uzaktan erişim portu fiziksel/mantıksal olarak kapatılarak risk izole edilir ve ilk planlı duruşta müdahale edilir.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?
Önce test edilir. Doğrudan canlı üretim hattında uygulanmaz. Canlı hattan izole edilmiş bir laboratuvar/test tezgahında (FAT/stating ortamı veya dijital ikiz simülasyonunda) test edilir; yamanın PLC döngü süresini ve I/O tepkilerini bozmadığı doğrulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?
Etkileyebilir. Emniyet fonksiyonunu yürüten Safety PLC ile haberleşen güvenlik kütüphanelerini, emniyet sağlama toplamını (safety checksum / CRC) veya sertifikalı emniyet yazılım bloklarını değiştirip değiştirmediği incelenerek anlaşılır; sağlama toplamı değişirse yeniden doğrulama (re-validation) şarttır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?
Zafiyet barındıran PLC portu endüstriyel güvenlik duvarı (firewall) ile tamamen engellenir, uzak servis bağlantısı varsayılan kapalıya alınır ve PLC ile ağ arasına derin paket denetimi (DPI) yapabilen bir IPS/IDS yerleştirilerek saldırı trafiği filtrelenir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Kimi ararsınız: OT Güvenlik / IT Sorumlusu ve Trepak Bakım Lideri. **İlk 3 Eylem:**

   Trepak uzak erişim modülünün / Jump Server'ın ağ kablosunu çekerek hattı izole etmek (enerjiyi kapatmadan).
   İnsan güvenliğini doğrulamak (hattaki operatörü döner kapaklama kafası ve dolum nozullarından uzaklaştırmak).
   Yetkisiz giriş yapılan servis hesabının oturumunu derhal sonlandırmak.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Emniyet güvende mi: Evet; bağımsız Safety PLC devresi ve STO hattı izole olduğu için fiziksel emniyet güvendedir (ancak konfigürasyon sağlama toplamı - Safety CRC kontrol edilmelidir).
   Neyi korursunuz (kanıt!): PLC bellek kopyasını (RAM/volatile memory dump), güvenlik duvarı (firewall) trafik kayıtlarını ve Jump Server oturum loglarını; cihazı kesinlikle resetlemeden korurum.
   Hangi hesap kapatılır: Yetkisiz erişim tespit edilen harici "Trepak Uzak Servis Hesabı" askıya alınır / kilitlenir.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Olayın gerçekleştiği tam zaman damgası (10:15), etkilenen varlık (Trepak Dolum/Kapatma PLC'si), kullanılan servis hesabının giriş noktası, saldırının aktif olarak kontrol altına alınıp alınmadığı ve olası fiziksel/emniyet riski taşıyıp taşımadığı bilgisi hazır olmalıdır.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök Neden: Servis hesabının zayıf/sızdırılmış kimlik bilgisi veya doğrudan açık port istismarı.
   Etki: Dolum/kapaklama PLC konfigürasyonuna yetkisiz müdahale şüphesi, geçici operasyonel duruş.
   Önlem & Görev Dağılımı: OT Mühendisi onaylı PLC yedek projesini geri yükler; IT/Siber Güvenlik ekibi MFA ve VPN zorunluluğunu devreye alır; Vardiya Sorumlusu emniyet testlerini (E-stop/ışık perdesi denetimi) tamamlayıp hattı üretime alır.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Jump Server ve Firewall bağlantı kayıtları (IP, oturum saatleri), Trepak PLC üzerinde yapılan kod/parametre değişiklik logları (Audit Trail), Safety PLC sağlama toplamı (Checksum) doğrulama tutanakları ve adli bilişim inceleme raporları korunmuş olmalıdır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · GENEL SÜRÜM · Şişeleme Hattı

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Kamera → YZ Modeli → OK / RED → Parametre → Robot

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

   Fiziksel donanım seviyesinde bağımsız ikinci bir kontrol (örneğin mekanik yükseklik sviçi veya pnömatik basınç sensörü) devreye girmelidir; kritik aşamalarda şüpheli parça doğrudan ıskarta/ayırma bandına yönlendirilmeli ve operatör ekranına (HMI) bildirim düşerek Human Override (insan müdahalesi/onayı) sağlanmalıdır.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

   Görüntü karelerinin zaman damgası (timestamp), FPS sürekliliği, piksel gürültüsü ve kamera bağlantı telemetrisi bağımsız bir Monitoring modülüyle izlenir. Donma, kararma veya anomali saptandığında girdi şüpheli sayılır; YZ kararı askıya alınıp sistem kural tabanlı Fallback moduna geçirilir ve hat güvenli hızda tutularak alarm verilir.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

   Görüntü karelerinin zaman damgası (timestamp), FPS sürekliliği, piksel gürültüsü ve kamera bağlantı telemetrisi bağımsız bir Monitoring modülüyle izlenir. Donma, kararma veya anomali saptandığında girdi şüpheli sayılır; YZ kararı askıya alınıp sistem kural tabanlı Fallback moduna geçirilir ve hat güvenli hızda tutularak alarm verilir.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Şişe/kapak hatasını YZ kaçırsa dahi mekanik limit sviçi torku sınırlar; parça ayrım istasyonuna atılarak operatör manuel incelemesine yönlendirilir (**Fail-Safe & Human Override**).
Girdi manipüle edildi	Kamera akışında veri gecikmesi/donması izleme servisi tarafından yakalanır; yapay zekâ devreden çıkarılıp standart sensör mantığına geçilir (**Monitoring & Fallback**).
Confidence düştü	Kamera akışında veri gecikmesi/donması izleme servisi tarafından yakalanır; yapay zekâ devreden çıkarılıp standart sensör mantığına geçilir (**Monitoring & Fallback**).

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.